

THE FORENSICS WAY

ISSUE 31

FORENSICS AWARENESS THIS WEEK

TUESDAY, SEPTEMBER 1, 2026

FRONT PAGE

NETWORK INFRASTRUCTURE

The Router That Lied to Its Own Admins: Fire Ant Rewrites Cisco IOS XR's Command Line to Hide Its Own Tunnels

Sygnia disclosed this week that the China-nexus actor it tracks as Fire Ant — overlapping with Mandiant's UNC3886 — has expanded a long-running campaign beyond VMware hypervisors to compromise Cisco IOS XR routers, TACACS authentication servers, and the Linux hosts used to manage them. Reverse engineering of the router implant showed it modifies the IOS XR command-execution path itself, appending exclusion filters to "show" commands so that tunnel source, destination, interface, and VRF details never appear to an administrator reading the router's own CLI output — the compromise is invisible from inside the device it lives on.

The campaign introduced two new tools: BridgeAgent, a Linux backdoor for persistence on management hosts, and TacTap, a TACACS credential-harvesting toolkit that injects directly into the running authentication daemon to intercept credentials from inside the process rather than off the wire. Forensic priority: never trust router CLI output alone — pull configuration and state via an out-of-band management path or vendor API and diff it against CLI output for exclusion-filter tampering, hunt TACACS daemon processes for unexpected loaded modules, and treat any Cisco IOS XR device with anomalous VRF or tunnel activity invisible to "show" commands as compromised.

ZERO-DAY

Two Bugs, No Password: Attackers Chain a PaperCut Auth Bypass Into Unauthenticated Code Execution

PaperCut shipped a second emergency patch this week after researchers and then real-world attackers chained two flaws in its NG/MF print management software into pre-authentication remote code execution. CVE-2026-81578 (CVSS 8.8) lets an unauthenticated request trigger backend administrative actions in

Threat Bulletin

ACTIVE EXPLOIT

CVE-2023-49105

ownCloud — an improper-authentication flaw first disclosed in 2023 is now under active exploitation, added to CISA KEV on August 27. Old, unpatched instances remain exposed years after a fix shipped. *Forensic Note:* Inventory every ownCloud deployment still in production regardless of age, confirm patch level, and review authentication logs for anomalous access predating the KEV addition — this flaw may already have been exploited quietly for years.

ACTIVE EXPLOIT

CVE-2026-66384

JFrog Artifactory — a path-traversal flaw allows a remote attacker to write files outside a restricted directory, potentially planting malicious artifacts into the software build pipeline. Added to CISA KEV August 27. *Forensic Note:* Review Artifactory access logs for path-traversal request patterns, audit recently modified artifacts for unauthorized changes, and treat any downstream build that consumed a suspect artifact as potentially poisoned.

MALWARE SPOTLIGHT

Nimbus Manticore — Iran's Espionage Toolkit Gets a New Backdoor

Researchers reported August 26 that the Iranian state-sponsored group Nimbus Manticore has expanded its toolset with a TWOSTROKE-like backdoor and a dedicated SSH

the web management interface before access validation completes; from there, an attacker edits a configuration file to reach CVE-2026-82078 (CVSS 9.4), an unsafe dynamic class-loading flaw in PaperCut's database connection utilities that loads driver classes by name with no allowlist. Honeypot telemetry shows exploitation in the wild beginning around August 29, with attackers using the chain to steal data from victim servers.

The class-loading flaw is the more durable lesson: any application that instantiates a class from a configurable, attacker-influenced string is one bypassed check away from remote code execution, regardless of language or framework. Forensic priority: review PaperCut Application Server logs for unauthenticated admin-function requests followed by configuration-file writes, hunt for unexpected JDBC driver class names in server configuration, and treat every unpatched pre-v24 through v26 PaperCut instance reachable from the network as breached until log review proves otherwise.

tunnel, giving operators a durable channel into target networks that blends with legitimate remote-administration traffic. The addition signals a shift toward longer-term network persistence rather than smash-and-grab espionage. *Forensic Note:* Hunt unexpected outbound SSH tunnel establishment from hosts with no administrative reason to run one, review process ancestry for the new backdoor's loader chain, and treat any unsanctioned SSH tunneling tool as a persistence indicator rather than a misconfiguration.

— PAGE 1 —

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, SEPTEMBER 1, 2026

CASE STUDIES: HISTORICAL GRID

SYNFUL KNOCK (2015)

The Firmware That Wouldn't Show Itself: How FireEye Found a Persistent Backdoor Hiding Inside Cisco Routers

In September 2015, FireEye's Mandiant unit disclosed SYNful Knock, a modified Cisco IOS firmware image found on routers across four countries that gave attackers persistent, unauthenticated access surviving normal reboots — activated by sending crafted TCP SYN packets to the device, a covert command channel that left no obvious trace in standard configuration review. Because the backdoor lived in the firmware itself rather than in a running process, conventional endpoint detection had nothing to see, and only integrity checks against known-

LOG4SHELL (2021)

One Log Line, Total Compromise: How a String Formatter Became the Internet's Worst Zero-Day

In December 2021, researchers disclosed CVE-2021-44228 — Log4Shell — a flaw in the ubiquitous Java logging library Log4j where a single attacker-controlled log message containing a JNDI lookup string could trigger remote class loading and code execution, instantly weaponizable against millions of internet-facing Java applications with zero authentication required. The underlying lesson — that dynamically loading a class or resource based on untrusted input is inherently dangerous, no matter how deep in the

good firmware hashes exposed it. It is a direct ancestor to this week's Fire Ant campaign: the same insight — that the network device administrators trust to tell the truth can be made to lie — now extended from firmware implants to live tampering with the CLI's own output.

application stack it happens — is exactly what this week's PaperCut chain rediscovered four years later in a different language and a different library, the same unsafe pattern wearing a new name.

DUQU (2011)

The Spy Built From Stuxnet's Bones: How a Word Document Zero-Day Turned Industrial Espionage Into Reconnaissance-as-a-Service

In September 2011, researchers at Hungary's CrySyS Lab uncovered Duqu, an espionage tool sharing significant source code with Stuxnet but built for information-gathering rather than sabotage — it arrived via a Microsoft Word document exploiting an unpatched kernel font-parsing zero-day, then quietly harvested keystrokes, system data, and design documents from industrial manufacturers to prepare future attacks. Its shared codebase with Stuxnet became one of the earliest cases where malware genealogy let investigators link a new campaign to an established, state-linked toolkit.

THE XZ UTILS BACKDOOR (2024)

The Two-Year Con: How a Patient Maintainer Takeover Nearly Backdoored SSH Across Every Major Linux Distribution

In March 2024, Microsoft engineer Andres Freund noticed SSH logins were consuming slightly more CPU than expected and taking a fraction of a second longer — an anomaly he chased into a multi-year social-engineering operation in which a persona named "Jia Tan" had spent two years building trust as a co-maintainer of xz Utils before slipping an obfuscated backdoor into the library's build scripts, positioned to compromise OpenSSH on affected distributions. The backdoor lived in autoconf test files and build-time binary blobs rather than the readable source, precisely so that code review would never catch it.

TOOLS OF THE TRADE

OPEN SOURCE

nfdump

SWITCH — V1.7.X

NetFlow/IPFIX collection and analysis toolkit for reconstructing traffic patterns from flow records rather than full packet capture. Ideal for tracing Fire Ant's traffic-collection activity on compromised routers when live packet capture on the device itself can't be trusted.

OPEN SOURCE

Frida

FRIDA PROJECT — V17.X

Dynamic instrumentation toolkit for hooking and tracing running processes. Attach it to a PaperCut Application Server (in a sandboxed reproduction) to trace the exact class-loading call path CVE-2026-82078 abuses, confirming which configuration values reached the vulnerable loader on a compromised host.

COMMERCIAL

Corelight

CORELIGHT — SENSOR V22

Zeek-based network detection and response appliance producing rich, structured logs of every connection. Deploy at network chokepoints around TACACS servers and router management VLANs to catch TacTap's credential-interception traffic and any tunnel activity Fire Ant hides from the router's own CLI.

UTILITY / SCRIPT

Autoruns

SYSINTERNALS — V14.X

The long-standing Windows and Linux autostart-location enumerator. Run it across hosts suspected of hosting Nimbus Manticore's new SSH tunneler to surface unauthorized persistence entries the backdoor needs to survive reboot, alongside any scheduled task launching it silently.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

**CVE-2026-65400 (APPLE
MACOS SCREEN SHARING)**

Improper-authentication flaw lets a remote attacker bypass credential checks for interactive Screen Sharing access; CVSS 9.8. CISA KEV. *Forensic Note:* Review Screen Sharing connection logs for unrecognized source IPs and confirm the current macOS security update is applied.

ARCHIVE ALERT

**CVE-2026-8037 (PROGRESS
KEMP LOADMASTER)**

Unauthenticated remote command execution in the load balancer's management interface; 792 exploit attempts across 65 IPs logged before the KEV addition. *Forensic Note:* Inventory internet-facing LoadMaster management interfaces and treat any reachable instance as compromised until artifact review proves otherwise.

RECENT MALWARE WATCH

ARCHIVE: AUGUST 25, 2026

**AMNESIA STEALER — THE
MACOS MALWARE THAT
WATCHES YOU WORK**

Harvests credentials from 16 Chromium browsers, iCloud Keychain, and crypto wallets, then opens a live Chrome DevTools Protocol screencast for real-time, attacker-driven session hijacking. Hunt unexpected processes holding open CDP debug ports on macOS endpoints.

ARCHIVE: AUGUST 18, 2026

**REVERSE_SSH — THE OPEN-
SOURCE BACKDOOR RIDING
VCENTER'S COATTAILS**

A legitimate open-source Go SSH tool dropped via malicious cron job after vCenter path-traversal access, giving operators a durable, signature-evading shell back into the environment. Hunt unexpected reverse_ssh binaries and unauthorized cron entries.